

SentinelML-ABAC: Sistema de Control de Acceso Industrial Resiliente a Ataques de Evasión

Ingeniería de Seguridad de Software

Caetano Flores, Jordan Guamán, Mesías Mariscal,
Anthony Morales, Leonardo Narváez, Denise Rea

Universidad de las Fuerzas Armadas ESPE

19 de julio de 2026



Agenda del Proyecto

- 1 Problema y Motivación
- 2 Marco Teórico Integrador
- 3 Solución Propuesta:
SentinelML-ABAC
- 4 Detalle Técnico y Ecuaciones
- 5 Gobernanza e ISO 27001
- 6 Conclusiones y Referencias

El Desafío de la Convergencia IT/OT y la IA

Entorno Industrial Crítico

Los sistemas SCADA y sensores IIoT se conectan mediante APIs analizadas por modelos de clasificación probabilística inteligentes.

La Nueva Amenaza: Evasión Adversaria (FGSM)

- Atacantes APTs inyectan ruido matemático imperceptible.
- Engañan al modelo haciendo pasar ataques como datos legítimos.
- Se elude la alerta del IDS y se sabotean los actuadores.



Unidad 1 y 2: Fundamentos

- **Tríada CIA:** Disponibilidad e integridad críticas en entornos OT.
- **Malware y Redes:** Botnets (ej., Mirai), rootkits, ataques MITM y replay.
- **Criptografía:** Cifrado híbrido (AES-256 para datos, ECC para firmas).

Unidad 2 y 3: Protocolos

- **Control de Acceso:** ABAC dinámico superando el RBAC estático.
- **Modelo Biba:** Integridad (*no-read-down, no-write-up*) para detener flujos de baja confianza.
- **Kerberos:** Autenticación centralizada por tickets, mitigando ataques Needham-Schroeder.

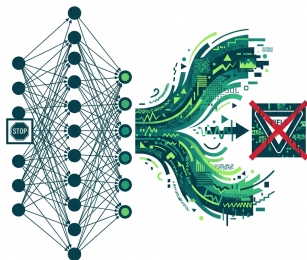
Seguridad de Modelos de ML en Producción

Vulnerabilidad Probabilística

Los modelos sufren de envenenamiento de datos en el entrenamiento y evasión (FGSM) en inferencia. Las APIs LLM sufren jailbreaks y fuga de información sensible.

Ciclo MLSecOps y NIST AI RMF

- **Firma de Pesos:** Validar hashes SHA-256 en PKI antes de montarlos.
- **Safetensors:** Evitar RCE en deserialización de Pickles.
- **Drift:** Monitoreo de desalineación (*PSI* y *Wasserstein*) para rollbacks rápidos.



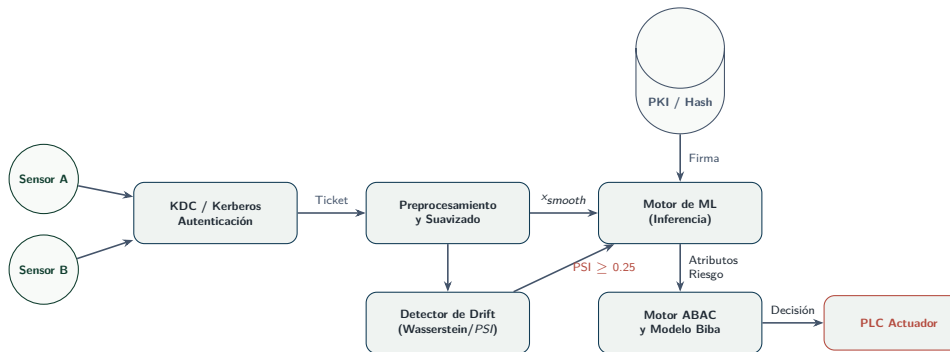
SentinelML-ABAC: Defensa Holística por Diseño

El tráfico pasa por tres compuertas lógicas antes de autorizar comandos físicos en la planta:

- ❶ **Criptográfica:** Tickets Kerberos y ECC para evitar suplantación y replay.
- ❷ **Preprocesamiento:** Suavizado y ruido gaussiano para mitigar perturbaciones FGSM.
- ❸ **Inferencia:** Safetensors sandboxed y control de acceso ABAC con integridad Biba.



Arquitectura del Sistema y Flujo de Inferencia



Fundamentación Matemática de la Resiliencia

Ataque Adversario (FGSM)

El atacante optimiza la señal para maximizar la pérdida L usando el gradiente:

$$x_{adv} = x + \epsilon \cdot \text{sign}(\nabla_x L(\theta, x, y))$$

Defensa por Suavizado Espectral

SentinelML aplica un suavizado móvil y ruido Gaussiano controlado $\eta \sim \mathcal{N}(0, \sigma^2)$ antes de la inferencia, destruyendo la perturbación imperceptible:

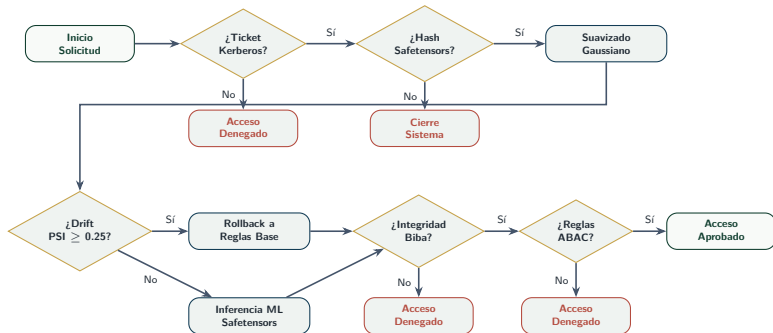
$$x_{smooth} = \text{Filter}(x_{adv}) + \eta$$

Monitoreo de Deriva (Wasserstein Distance)

Cálculo del Earth Mover's Distance para determinar la degradación probabilística:

$$W_1(P_r, P_g) = \inf_{\gamma \in \Pi(P_r, P_g)} \mathbb{E}_{(x,y) \sim \gamma} [\|x - y\|]$$

Flujo Lógico del Guardrail de Inferencia y Autorización



Gobernanza bajo ISO/IEC 27001 y Ciclo PDCA

Ciclo de Mejora Continua (PDCA)

- **Plan:** Políticas de IA y riesgos (MITRE ATLAS).
- **Do:** Cifrado, preprocesador y sandboxing.
- **Check:** Monitorear drift y realizar Red Teaming.
- **Act:** Cuarentena, rollbacks y re-entrenamiento.

Gobernanza Documental

Cumplimiento mediante políticas, procedimientos operativos, instrucciones técnicas y registros de auditoría.



Conclusiones y Lecciones Clave

- **Seguridad de IA Holística:** Asegurar sistemas inteligentes exige blindar tanto las APIs de red clásicas como la integridad matemática del clasificador.
- **Resiliencia Proactiva:** El suavizado espectral y rollbacks en caliente en menos de 5 segundos conmutan de forma segura ante intrusiones complejas de evasión.
- **Consistencia de Integridad:** La formalización del modelo de Biba sobre el control ABAC previene contaminaciones de datos de baja confianza.
- **Auditoría y Estándares:** La alineación con NIST AI RMF, MITRE ATLAS e ISO 27001 otorga un marco de cumplimiento técnico-administrativo corporativo.

Estándares y Literatura Científica

- [1] NIST. (2018). *NIST SP 800-53, Rev. 5: Security and Privacy Controls*.
- [2] ISO/IEC. (2022). *ISO/IEC 27001:2022: Information Security Management Systems*.
- [3] Goodfellow, I. J., et al. (2014). *Explaining and harnessing adversarial examples*. arXiv:1412.6572.
- [4] NIST. (2023). *Artificial Intelligence Risk Management Framework (AI RMF 1.0)*.